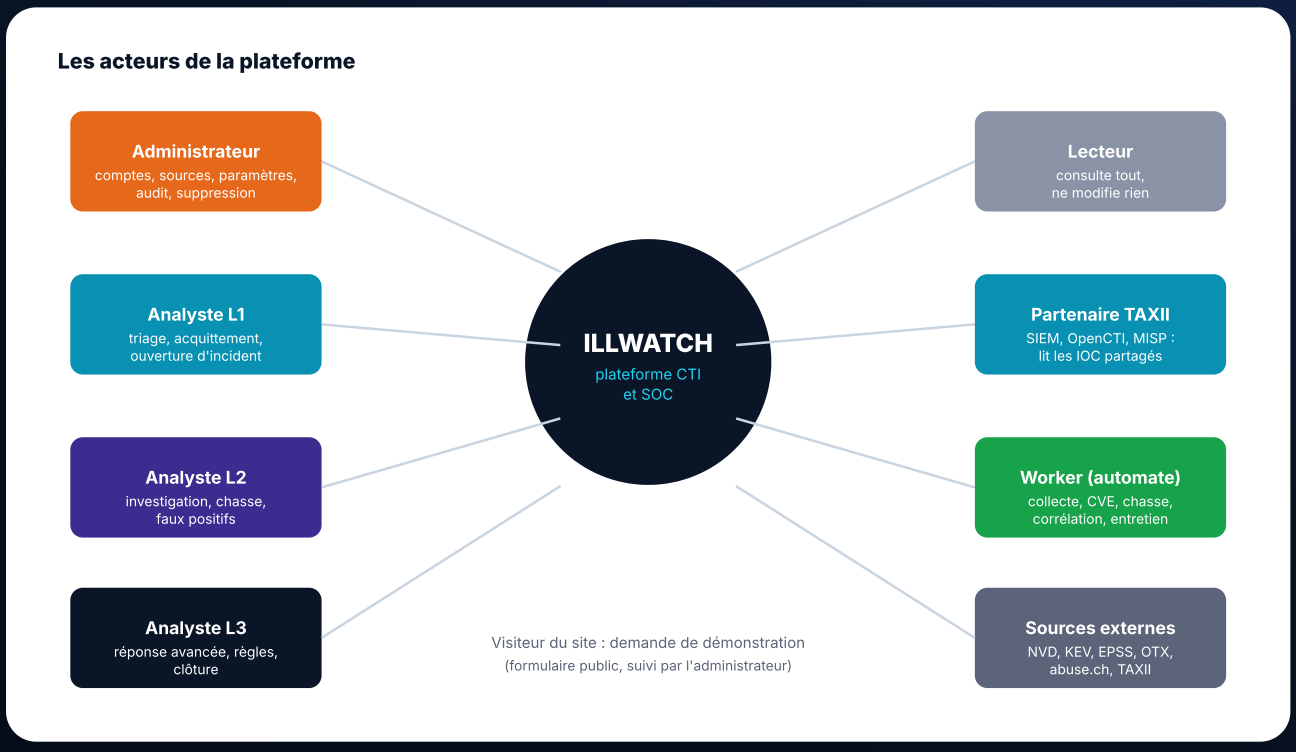
ILL Watch

MANUEL FONCTIONNEL

Acteurs, fonctionnalités et actions

Qui fait quoi sur la plateforme, et comment chaque fonctionnalité fonctionne : renseignement, score des vulnérabilités, corrélation avec vos actifs, incidents, chasse, contexte ATT&CK, partage et pilotage.



VERSION
2.0 · 30 octobre 2026

LOGICIEL
ILLWATCH 0.2.0.dev0

AUTEUR
Godwill FOKA · CyberillSec, une initiative CYBERILL

POUR QUI
Analyste SOC, responsable sécurité, décideur, contributeur

Sommaire

1 1. ILLWATCH en un coup d'œil 1

2 2. Les acteurs et leurs droits 3

3 3. Le renseignement : sources et indicateurs 6

4 4. Les vulnérabilités : score et priorités 10

5 5. Corrélation : le renseignement rapporté à vos actifs 13

6 6. Triage et incidents 16

7 7. Chasse aux menaces 18

8 8. Contexte adverse : MITRE ATT&CK et campagnes 20

9 9. Partage et exports 22

10 10. Pilotage et tableau de bord 23

11 11. Administration, audit et sécurité 24

12 12. Ce que la plateforme fait seule 25

13 13. Parcours types 26

14 14. Glossaire 27

Version en ligne, toujours à jour : https://godwillfoka.github.io/cyberillsec-illwatch/
Les numéros de page renvoient au pied de page du document.

Version 2.0 du 30/10/2026 · ILLWATCH `0.2.0.dev0` · Public : responsable sécurité, analyste SOC, décideur, contributeur

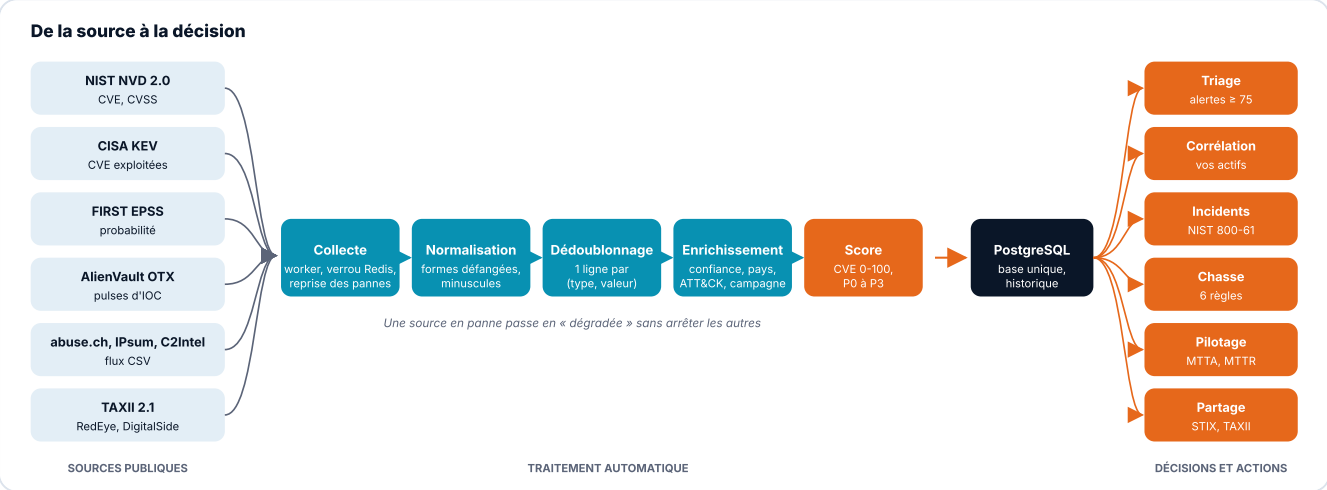
Ce manuel explique **ce que fait** ILLWATCH, **qui** peut faire quoi, et **comment** chaque fonctionnalité fonctionne. Les étapes d'installation et les gestes du quotidien sont dans le Guide d'installation et d'exploitation.

Chaque fonctionnalité est présentée en quatre temps : **à quoi elle sert**, **comment elle fonctionne**, **comment l'utiliser** (dans l'application, en ligne de commande, par l'API) et **comment lire le résultat**.

---

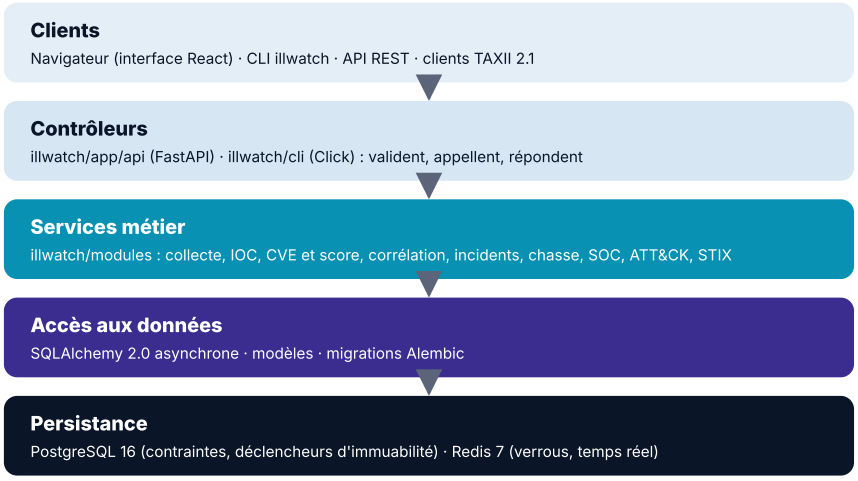
1. ILLWATCH en un coup d'œil

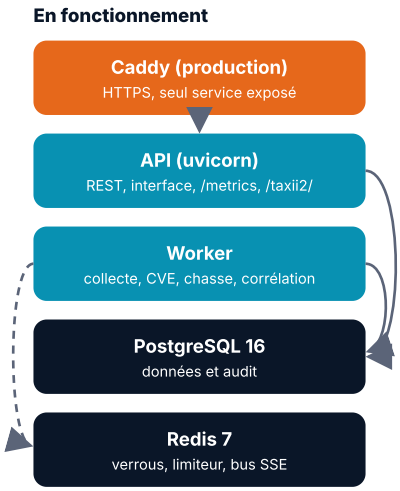
ILLWATCH fait le travail répétitif d'un analyste de sécurité (collecter, dédoublonner, noter, corréler) pour qu'il ne garde que les **décisions** : quoi corriger d'abord, quoi bloquer, quel incident ouvrir, et la preuve de ce qui a été fait.



Question de l'équipe	Réponse d'ILLWATCH	Où
Quelle vulnérabilité corriger d'abord ?	score de 0 à 100 et priorité P0 à P3, fondés sur l'exploitation réelle	CVE et priorités, Triage
Est-ce que ça nous concerne ?	corrélation avec l'inventaire : produits, versions, adresses, domaines	Corrélations
Cette adresse est-elle malveillante ?	base d'IOC dédoublonnée, avec confiance, provenance et contexte	Indicateurs
Sommes-nous déjà touchés ?	chasse sur un export de journaux ou sur toute la base	Chasse
Où en est la réponse ?	incidents au cycle NIST, niveaux L1 à L3, délais cibles	Incidents, Pilotage
Pouvons-nous le prouver ?	chronologies et journal d'audit immuables	Incidents, Administration

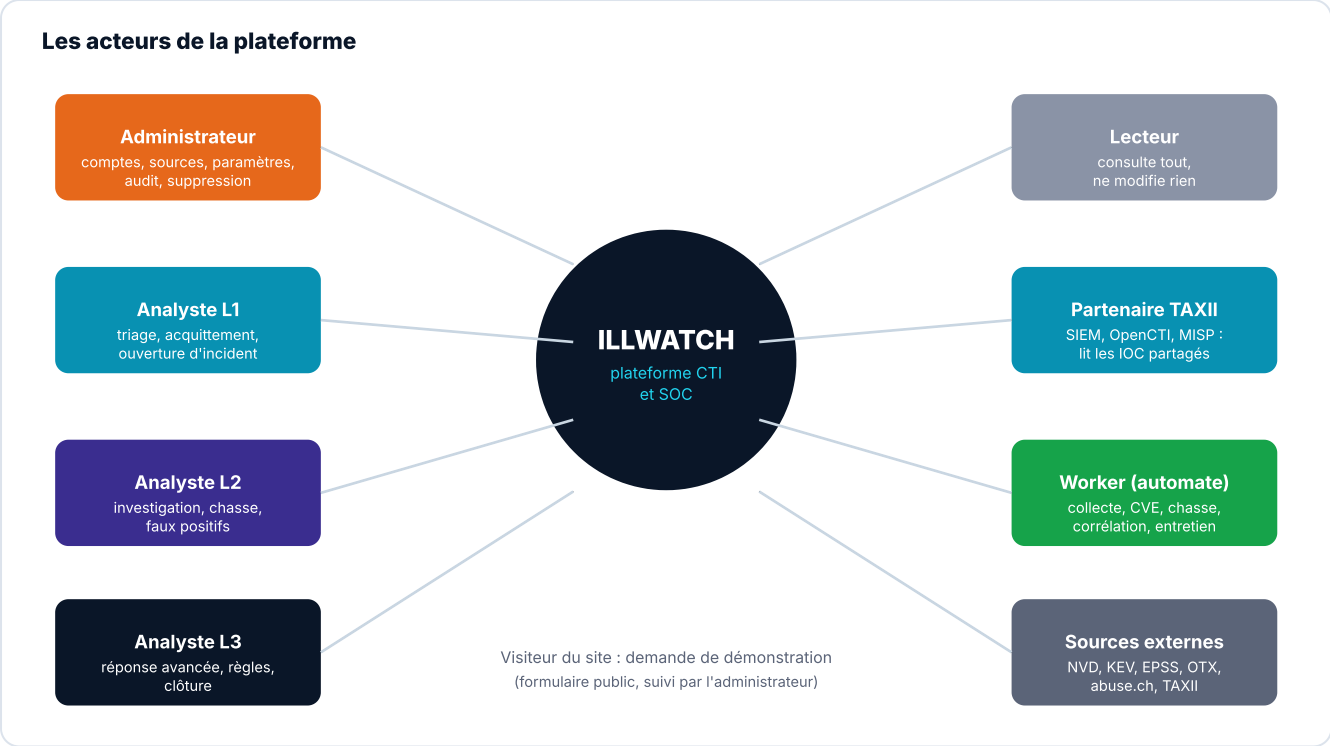
Architecture d'ILLWATCH : un monolithe modulaire en couches





Dépendance strictement descendante : une couche ne connaît que celle du dessous.

2. Les acteurs et leurs droits



2.1 Les acteurs humains

Acteur	Rôle dans ILLWATCH	Missions
Administrateur	ADMIN	gère les comptes, les sources, les paramètres ; supprime ; lit le journal d'audit ; suit les demandes de démonstration
Analyste	ANALYST	trie les alertes, conduit les incidents, chasse, déclare l'inventaire, écarte les faux positifs, crée les campagnes
Lecteur	VIEWER	consulte tous les écrans sans rien modifier (direction, auditeur, stagiaire)
Partenaire TAXII	VIEWER dédié	un SIEM, OpenCTI ou MISP qui lit les IOC partagés par le serveur TAXII
Visiteur du site	aucun compte	demande une démonstration par le formulaire public du site de présentation

> **Rôles et niveaux SOC, deux notions distinctes**
>
> Le **rôle** (administrateur, analyste, lecteur) fixe ce qu'un compte a le droit de faire. Le **niveau SOC** (L1, L2, L3) indique où en est un **incident** dans l'escalade : un même analyste peut traiter un incident en L1 le matin et un autre en L3 l'après-midi.

2.2 Les acteurs automatiques

Acteur	Ce qu'il fait
Worker	collecte les sources, synchronise les CVE toutes les 6 h, corrèle chaque heure, chasse et fait l'entretien chaque jour
Sources externes	NIST NVD, CISA KEV, FIRST EPSS, AlienVault OTX, abuse.ch, IPsum, C2IntelFeeds, serveurs TAXII (RedEye, DigitalSide), MITRE ATT&CK, DB-IP
Webhook d'alerte	reçoit chaque alerte CVE (Slack, Mattermost) si `ALERT_WEBHOOK_URL` est renseigné
Prometheus et Grafana	lisent `/metrics` et alertent si une source ou le worker s'arrête

2.3 Qui peut faire quoi

Matrice établie à partir des contrôles réels de l'API (chaque refus est consigné au journal d'audit sous `authz.denied`). « App » : dans l'application ; « CLI » : en ligne de commande, où l'opérateur du serveur agit sans compte (actions attribuées à l'utilisateur système).

Action	Admin	Analyste	Lecteur	Méthodes
Consulter tous les écrans et données	✅	✅	✅	App, API
Créer, modifier, désactiver un compte ; réinitialiser un mot de passe	✅			App, CLI, API
Lire le journal d'audit et les paramètres	✅			App, CLI, API
Ajouter, régler, suspendre, supprimer une source	✅			App, CLI, API
Déclarer, modifier, importer, exporter l'inventaire	✅	✅		App, CLI, API
Supprimer un actif	✅			App, CLI, API
Télécharger le modèle d'inventaire	✅	✅	✅	App, CLI, API
Acquitter une alerte CVE ; ouvrir l'incident de réponse	✅	✅		App, CLI, API
Lancer une corrélation ; acquitter un évènement ; le qualifier de faux positif	✅	✅		App, CLI, API
Ouvrir, assigner, faire avancer, escalader un incident ; ajouter une note	✅	✅		App, CLI, API
Associer un IOC ou une CVE à un incident ; chasser depuis l'incident	✅	✅		App, API
Lancer une chasse	✅	✅		App, CLI, API

Action	Admin	Analyste	Lecteur	Méthodes
Soumettre un lot d'IOC	✅	✅		App, API
Mettre une valeur en liste d'exclusion (faux positif)	✅	✅		App, CLI, API
Retirer une exclusion	✅			App, API
Créer, modifier une campagne ; y rattacher des IOC	✅	✅		App, CLI, API
Supprimer une campagne	✅			App, API
Exporter CSV, JSON, STIX 2.1 ; lire le serveur TAXII	✅	✅	✅	App, CLI, API
Suivre les demandes de démonstration	✅			App, CLI, API

3. Le renseignement : sources et indicateurs

3.1 Les sources

À quoi elles servent. Alimenter la base d'indicateurs de compromission (IOC) avec du renseignement public et gratuit.

Comment ça fonctionne. Le worker se réveille chaque minute et collecte chaque source dont l'intervalle est écoulé, sous un verrou Redis (deux instances ne collectent jamais la même source en même temps). Cinq formats sont pris en charge : CSV, JSON, STIX 2.1, TAXII 2.1 et l'API AlienVault OTX. Chaque collecte est inscrite au journal des collectes (volumes, durée, erreur). Une source en échec passe en *dégradée*, ses essais sont espacés (1, 2, 4 minutes…), et les autres sources continuent.

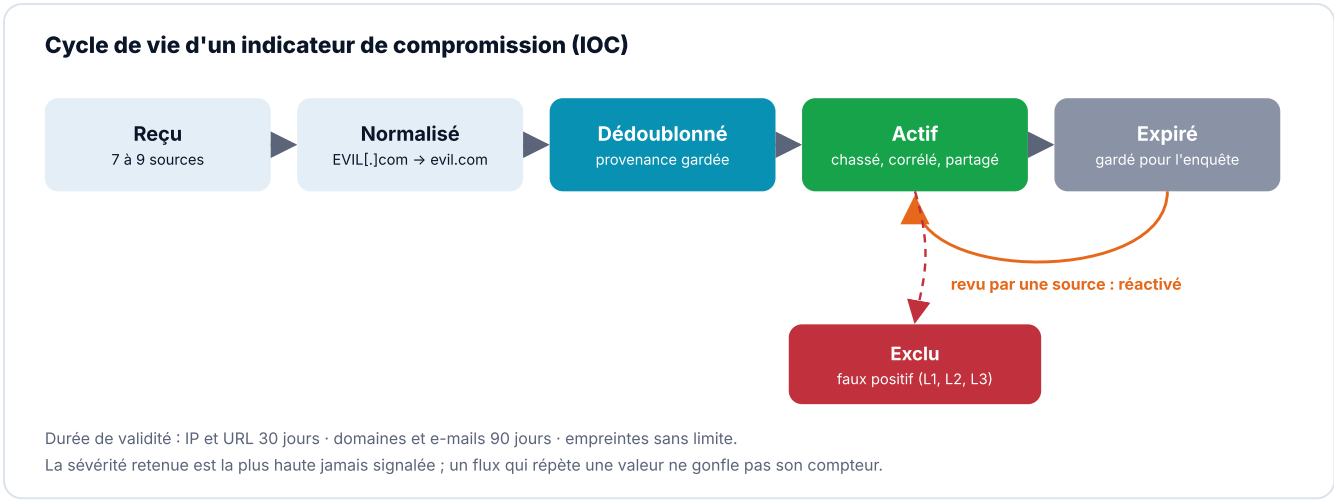
Source de référence	Format	Contenu	Fiabilité par défaut
abuse.ch URLhaus	CSV	URL malveillantes récentes (clé abuse.ch)	B
abuse.ch Feodo Tracker	CSV	serveurs de commande de botnets	B
C2IntelFeeds (adresses, domaines)	CSV	serveurs de commande des 30 derniers jours	C
IPsum	CSV	adresses présentes dans au moins 5 listes noires	B
RedEye	TAXII 2.1	indicateurs STIX (jeton gratuit)	C
DigitalSide (URL, réseau)	CSV, TAXII 2.1	URL et IOC réseau ; désactivées par défaut (serveur souvent hors ligne)	C
AlienVault OTX	OTX	pulses de la communauté (clé gratuite)	D

Sécurité. Une source doit être publique et en HTTPS. Avant chaque requête, ILLWATCH vérifie que l'adresse résolue est publique (protection SSRF) ; la taille des réponses est plafonnée ; les clés ne sont jamais stockées en base et ne partent que vers leur hôte officiel.

Utiliser. Écran **Sources CTI** (voir le guide, section 4) ; `illwatch feeds list | probe | add | enable | disable | fetch | fetch-all` ; `/api/v1/feeds`.

Lire le résultat. *Saine* : dernière collecte réussie. *Dégradée* : la dernière a échoué (le motif est dans le détail). *En attente* : jamais collectée. *Suspendue* : désactivée par un administrateur.

3.2 Le cycle de vie d'un IOC

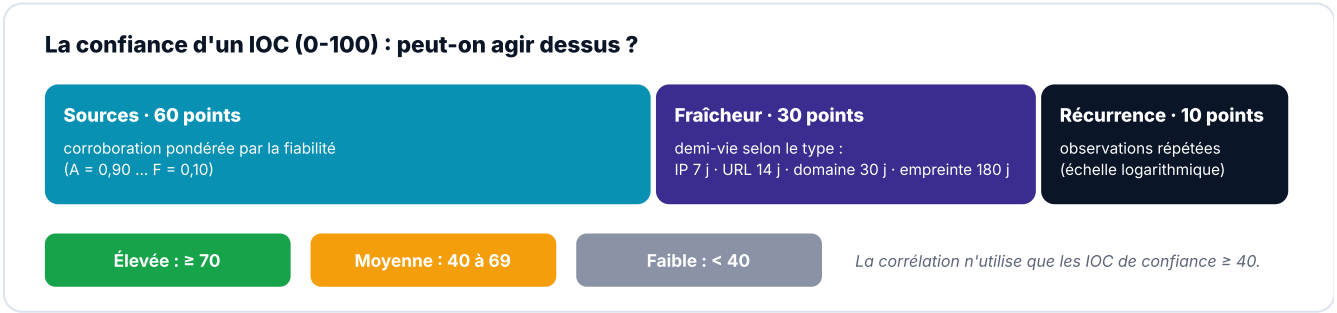


Comment ça fonctionne.

1. **Normalisation** : les formes défangées sont refaites (`hxxps://evil[.]com` devient `https://evil.com`), domaines, e-mails et empreintes passent en minuscules, les adresses IP sont canonisées. Types reconnus : IPv4, IPv6, plage réseau (CIDR), domaine, URL, e-mail, empreintes MD5, SHA-1, SHA-256.
2. **Dédoublonnage** : un IOC est identifié par le couple (type, valeur normalisée) ; la base garantit l'unicité. La **provenance** de chaque source est gardée (première et dernière observation, nombre d'observations par source).
3. **Sévérité** : la plus haute jamais signalée par une source.
4. **Expiration** : adresses et URL 30 jours après la dernière observation, domaines et e-mails 90 jours, empreintes jamais. Un IOC expiré est **conservé** pour l'enquête, mais n'est plus actif ; une nouvelle observation le réactive.
5. **Exclusion** : un IOC qualifié de faux positif reste en base, mais n'est plus ni compté, ni chassé, ni corrélé, ni partagé.

Une valeur invalide est **refusée et listée**, jamais ignorée en silence.

3.3 La confiance d'un IOC



À quoi elle sert. Répondre à « peut-on agir sur cet indicateur ? », indépendamment de sa gravité. Une adresse confirmée par trois sources fiables et vue hier vaut plus qu'une adresse signalée une fois il y a trois semaines.

Comment ça se calcule (0 à 100).

- **Sources, 60 points** : probabilité qu'au moins une source dise vrai, $1 - \Pi(1 - w_i)$, avec un poids par fiabilité (A 0,90, B 0,75, C 0,50, D 0,30, E 0,15, F 0,10). Deux sources « C » valent plus qu'une seule.

- **Fraîcheur, 30 points** : décroissance exponentielle depuis la dernière observation, avec une demi-vie selon le type (adresse 7 jours, URL 14, domaine 30, e-mail 60, empreinte 180).
- **Récurrence, 10 points** : observations répétées, en échelle logarithmique.

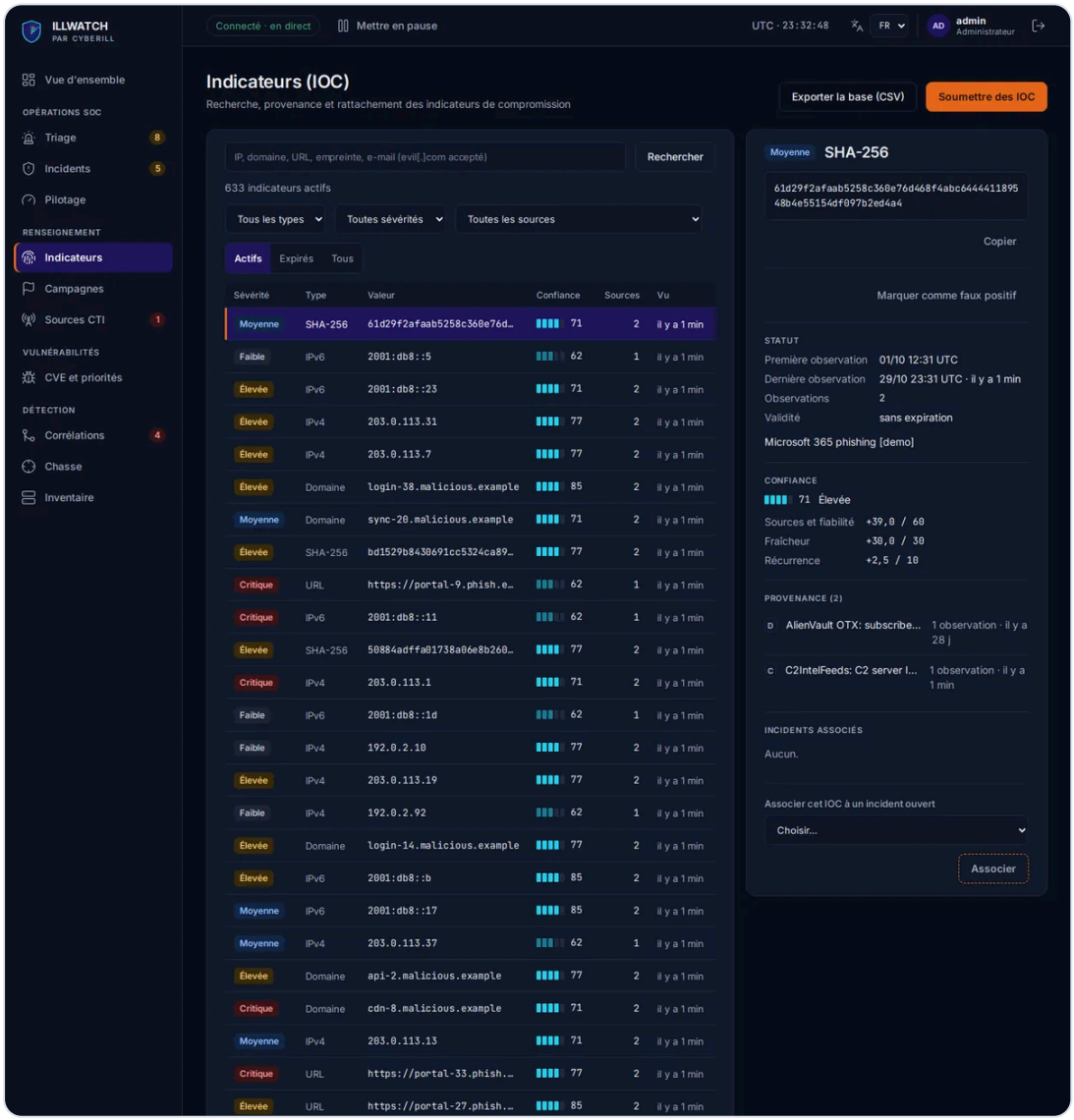
Un IOC soumis à la main compte comme une source de fiabilité C.

Lire le résultat. Élevée (70 et plus), moyenne (40 à 69), faible (moins de 40). La corrélation n'utilise que les IOC de confiance 40 et plus (`CORRELATION_MIN_CONFIDENCE`).

3.4 L'enrichissement des adresses IP

La fiche d'une adresse affiche son **pays** et son **système autonome** (opérateur), lus dans la base DB-IP Lite importée localement : **aucune requête sortante** à la consultation. Une adresse privée, réservée ou de documentation est signalée comme non routable. Mise à jour mensuelle automatique après un premier `illwatch enrich update`.

3.5 Utiliser l'écran Indicateurs



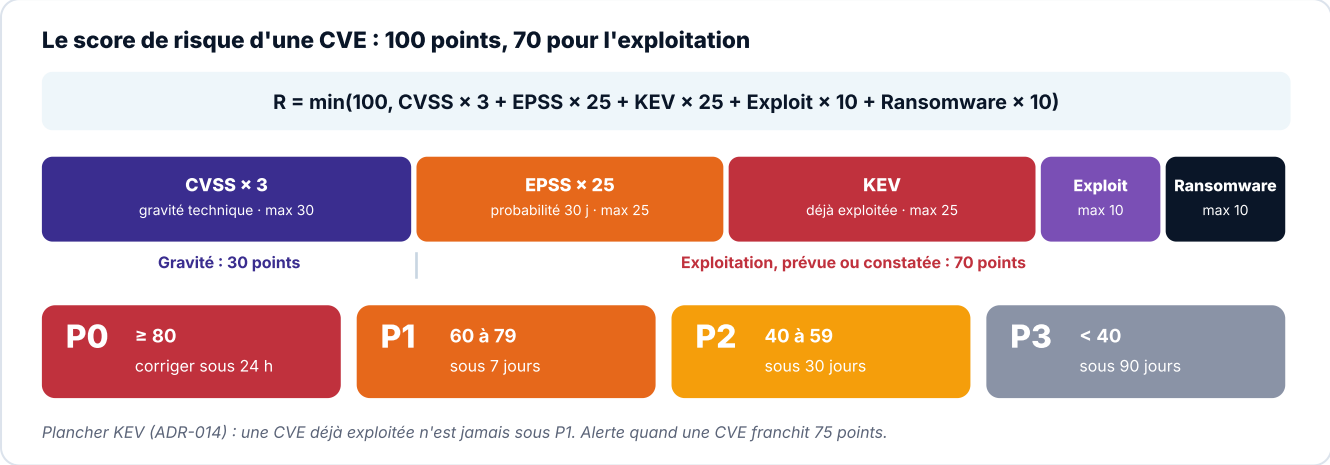
Action	Dans l'application	En ligne de commande ou API
Chercher une valeur	champ « Valeur recherchée » (`evil[.]com` accepté)	`GET /api/v1/indicators?q=…`
Filtrer	état (actifs, expirés, tous), type, sévérité minimale, source	idem, paramètres de requête
Lire la fiche	confiance décomposée, provenance, enrichissement, incidents liés	`GET /api/v1/indicators/{id}`
Soumettre un lot	**Soumettre des IOC** (une valeur par ligne)	`POST /api/v1/indicators`
Écarter un faux positif	**Marquer comme faux positif**, avec le motif	`illwatch soc exclude <valeur> --reason "…"`
Exporter	**Exporter** (CSV, audité)	`illwatch dashboard export iocs --format csv -o iocs.csv`

4. Les vulnérabilités : score et priorités

4.1 À quoi sert le score

Des dizaines de milliers de vulnérabilités (CVE) sont publiées chaque année. La plupart ne seront jamais exploitées. Le score dit **laquelle corriger d'abord**, en s'appuyant sur l'exploitation réelle plutôt que sur la seule gravité théorique.

4.2 Comment le score se calcule




```
R = min(100, CVSS × 3 + EPSS × 25 + KEV × 25 + Exploit × 10 + Ransomware × 10)
```

Facteur	Source	Valeur	Points
CVSS : gravité technique, de 0 à 10	NIST NVD	note × 3	0 à 30
EPSS : probabilité d'exploitation dans les 30 jours, de 0 à 1	FIRST	probabilité × 25	0 à 25
KEV : déjà exploitée dans la nature	CISA	25 si présente	0 ou 25
Exploit public	référence NVD étiquetée « Exploit »	10 si présent	0 ou 10
Ransomware : utilisée par des rançongiciels	CISA KEV	10 si connu	0 ou 10

Les poids somment exactement à 100 : la borne `min(100, …)` est une sécurité, jamais un écrêtage. Le parti pris est clair : **30 points pour la gravité, 70 pour l'exploitation**, prévue (EPSS) ou constatée (KEV, exploit, rançongiciel). Ces poids viennent du cahier des charges et sont arbitrés par l'ADR-001.

4.3 Les priorités et leurs délais

Priorité	Score	Délai de remédiation	Sens
P0	80 et plus	24 heures	critique : en pratique, une faille déjà exploitée et très probable
P1	60 à 79	7 jours	haute

Priorité	Score	Délai de remédiation	Sens
P2	40 à 59	30 jours	à planifier
P3	moins de 40	90 jours	maintenance standard

Plancher KEV (ADR-014). Une CVE du catalogue KEV n'est jamais sous P1, quelle que soit la formule : une faille exploitée ne peut pas être de la maintenance standard (aligné sur la directive CISA BOD 22-01). Si EPSS est momentanément indisponible, la dernière valeur connue est conservée ; au-delà de 48 heures, `illwatch status` le signale.

Exemple	CVSS	EPSS	KEV	Exploit	Rançon	Score	Priorité
Log4Shell	30	23,5	25	10	10	98,5	P0
CVE KEV, CVSS 9,8, EPSS 0,05	29,4	1,3	25	0	0	55,7	P1 (plancher KEV)
Hors KEV, CVSS 7,5, EPSS 0,90, exploit	22,5	22,5	0	10	0	55	P2
Hors KEV, CVSS 9,8, EPSS 0,02	29,4	0,5	0	0	0	29,9	P3

4.4 Ce que donne le tri sur données réelles



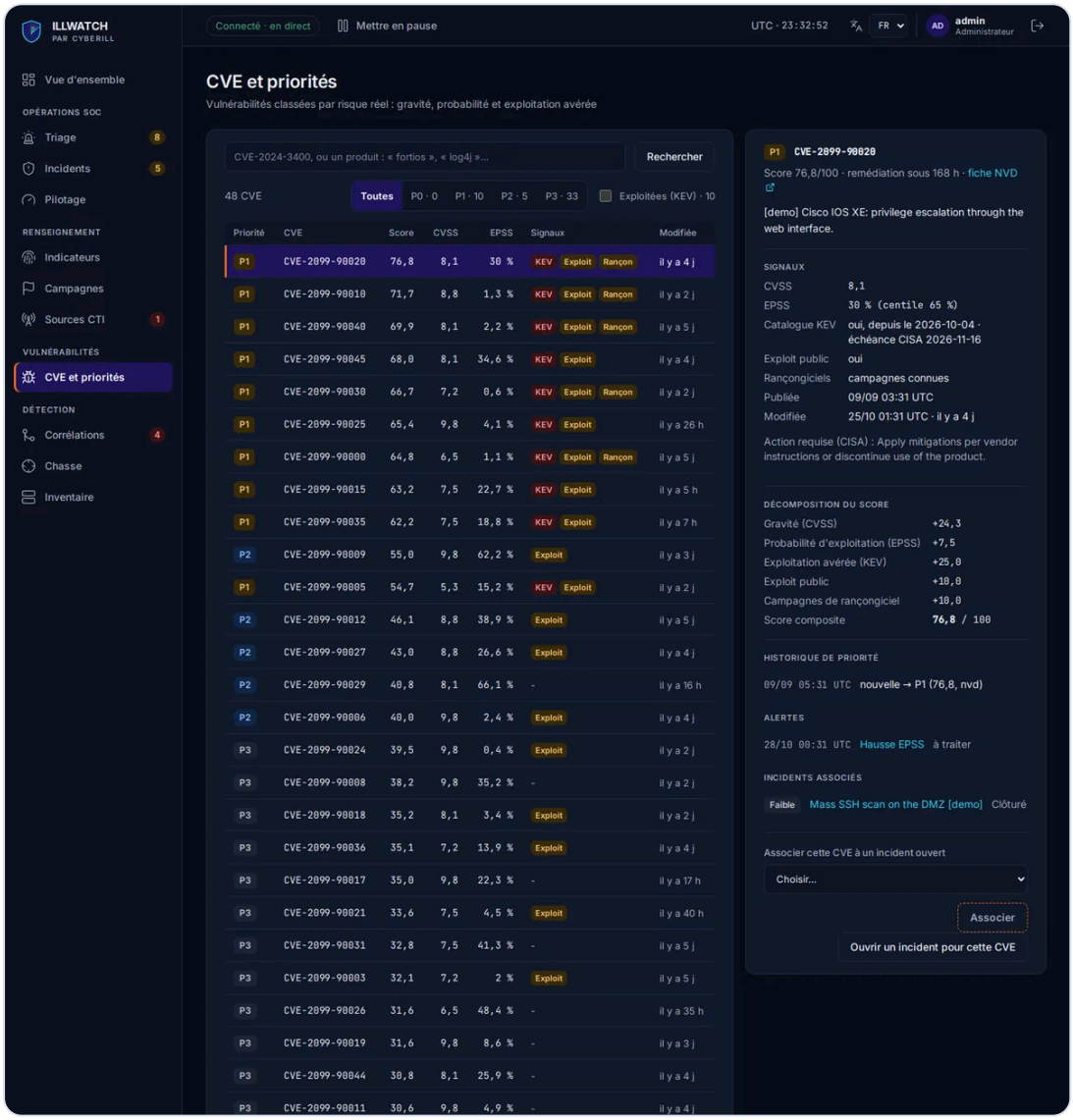
4.5 Les alertes

Une **alerte** est émise quand le score d'une CVE franchit **75** vers le haut (`RISK_ALERT_THRESHOLD`), soit avant même son passage en P0. Elle est enregistrée, journalisée, puis envoyée au webhook (5 tentatives au plus). La **première synchronisation** sert de ligne de base et n'alerte pas : une équipe qui reçoit 400 alertes le premier jour apprend à les ignorer. Chaque changement de priorité est historisé, avec l'ancien et le nouveau score.

4.6 Utiliser

Action	Dans l'application	En ligne de commande ou API
Liste par risque	**CVE et priorités** : recherche, priorité, « Exploitées (KEV) »	`illwatch cves list --priority P0_CRITIQUE`

Action	Dans l'application	En ligne de commande ou API
Comprendre un score	fiche : signaux, décomposition, historique, action requise par la CISA	`illwatch cves show CVE-…`, `GET /api/v1/cves/{id}`
Ouvrir un incident	**Ouvrir un incident pour cette CVE**	`illwatch incidents from-alert <id>`
Synchroniser	(automatique, toutes les 6 h)	`illwatch cves sync [--only kev|nvd|epss]`
Travailler hors ligne		`illwatch cves import CVE-2024.json.xz --only-known`

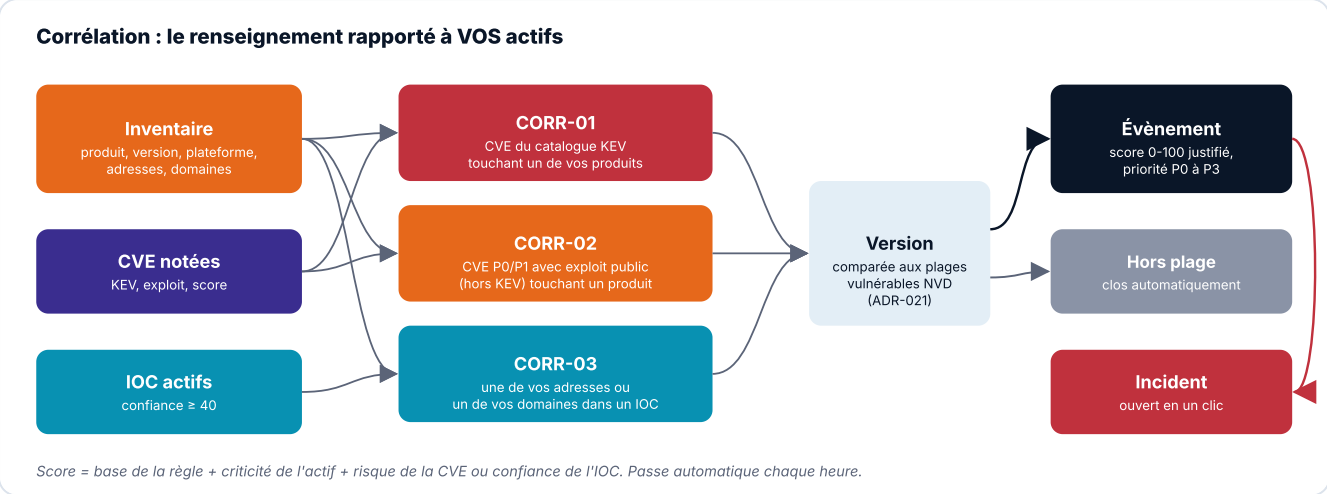


5. Corrélation : le renseignement rapporté à vos actifs

5.1 À quoi elle sert

Passer de « il existe une CVE critique » à « **votre pare-feu du siège** est touché par une CVE exploitée ». C'est la fonctionnalité qui transforme une base de renseignement en outil de décision pour votre organisation.

5.2 Comment elle fonctionne



Règle	Déclencheur	Base	Technique ATT&CK
CORR-01	une CVE du catalogue KEV touche un produit de l'inventaire	60	exploitation d'une application exposée
CORR-02	une CVE P0 ou P1 avec exploit public (hors KEV) touche un produit	45	idem
CORR-03	une de vos adresses ou un de vos domaines figure dans un IOC actif de confiance 40 et plus	50	-

Score de l'évènement (0 à 100) = base de la règle + criticité de l'actif (faible 0, moyenne 5, élevée 12, critique 20) + signal (score de la CVE × 0,2, ou confiance de l'IOC × 0,3). La priorité suit la même grille que les CVE.

Exemple

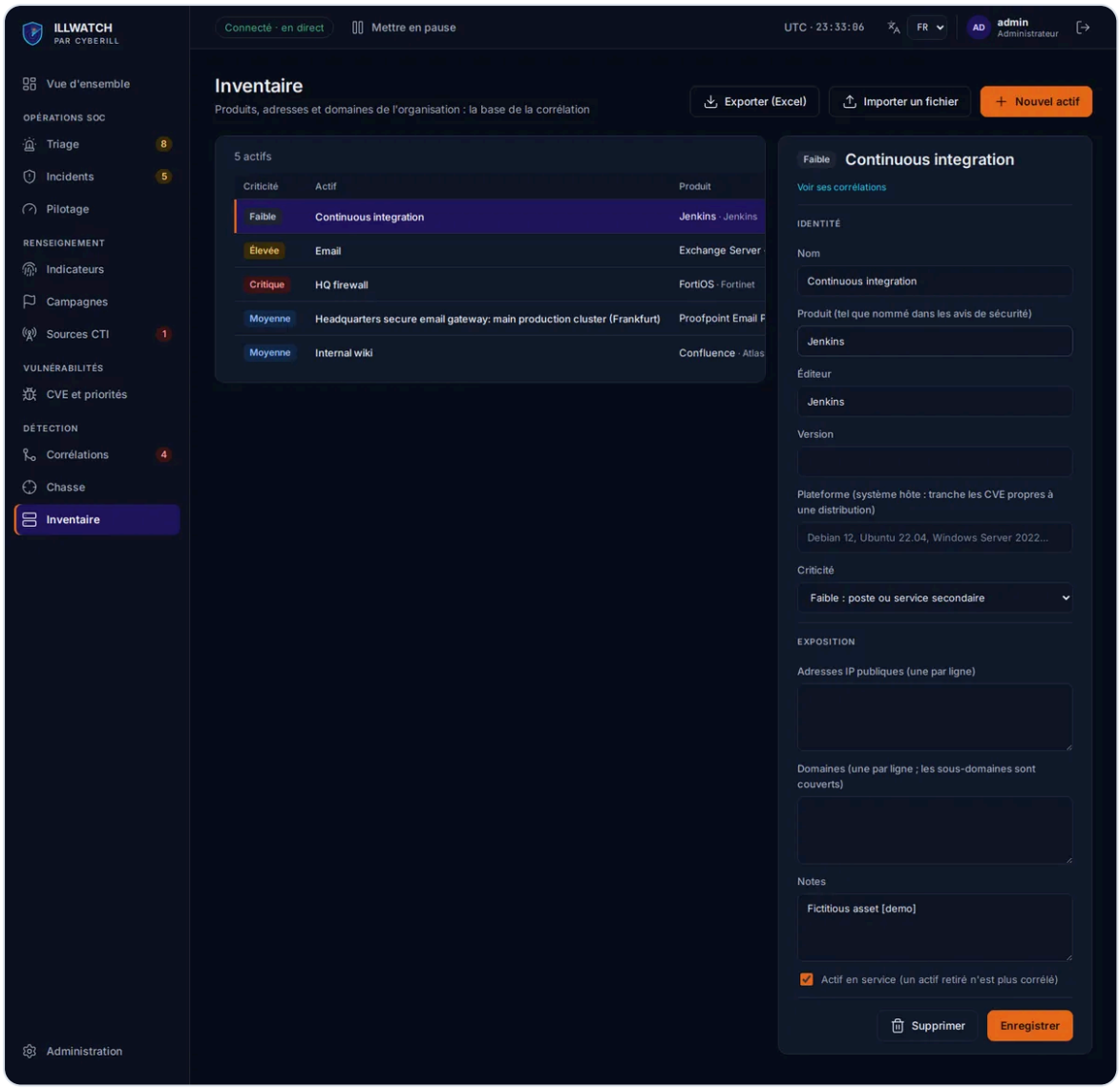
: une CVE KEV de score 70 sur un actif de criticité élevée donne 60 + 12 + 14 = 86, donc P0.

Comparaison des versions (ADR-021). Quand l'actif a une version, elle est comparée aux plages vulnérables publiées par la NVD : hors plage, l'évènement est clos automatiquement ; sur une autre plateforme que celle de l'actif, il est écarté. Sur données réelles, la première passe sans comparaison des versions a produit 38 évènements, dont aucun vrai positif ; avec la comparaison, 37 ont été clos automatiquement et le dernier requalifié.

Cycle de l'évènement. Unique par règle et par couple (actif, CVE ou IOC) ; une nouvelle passe le met à jour ; acquitté, il est rouvert s'il monte d'un cran de priorité ; qualifié de faux positif, il ne revient jamais.

5.3 Utiliser

Action	Dans l'application	En ligne de commande ou API
Déclarer l'inventaire	**Inventaire** : **Importer un fichier** (Excel, CSV) ou **Nouvel actif**	`illwatch assets template`, `assets import`, `assets add`
Lancer une passe	**Corréler maintenant** (sinon chaque heure)	`illwatch correlate run`
Lire les évènements	**Corrélations** : à traiter ou tous, filtre par actif	`illwatch correlate list [--all]`
Acquitter	**Acquitter**	`POST /api/v1/correlations/{id}/ack`
Ouvrir l'incident	**Ouvrir l'incident** (reprend la CVE ou l'IOC)	`POST /api/v1/correlations/{id}/incident`
Écarter	**Qualifier de faux positif**, motif obligatoire	`POST /api/v1/correlations/{id}/false-positive`
Mesurer la qualité		`illwatch correlate evaluate` (jeu figé, aucune écriture)



5.4 Lire le résultat

Le détail d'un évènement répond à **pourquoi** : règle, actif et criticité, produit reconnu, version et plateforme, signaux (KEV, échéance CISA, exploit), confiance et localisation de l'IOC, puis la décomposition du score et l'historique (première détection, dernière confirmation).

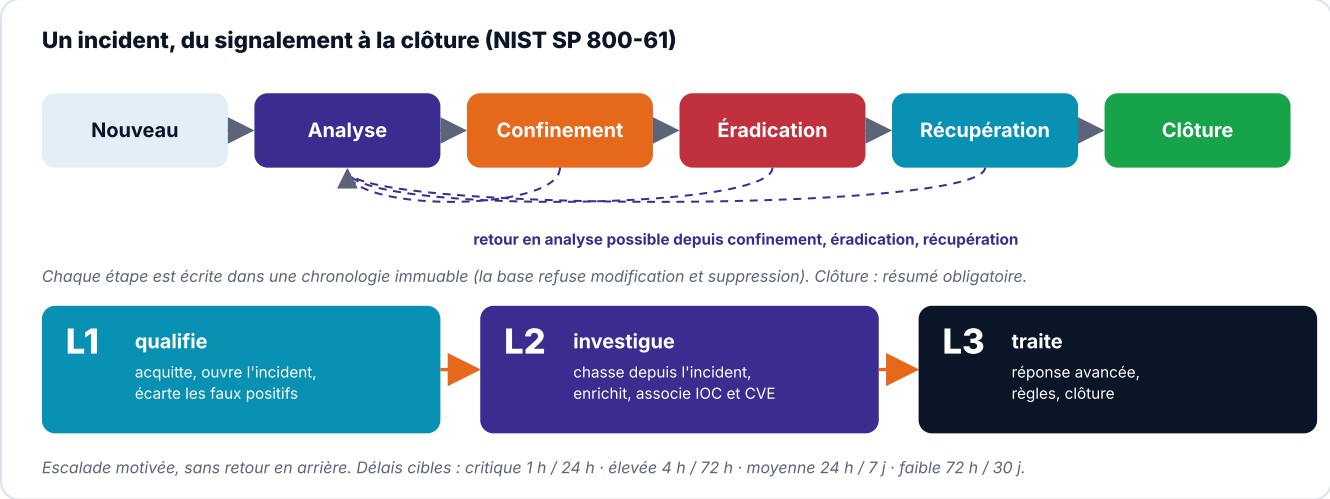
---

6. Triage et incidents

6.1 Le triage des alertes

À quoi il sert. Qualifier chaque alerte CVE : la voir (**acquitter**) ou y répondre (**ouvrir l'incident**). L'écran **Triage** présente la file par priorité puis ancienneté ; le panneau d'une alerte montre l'origine (catalogue KEV, hausse d'EPSS, mise à jour NVD), le score avant et après, l'état de la notification, la vulnérabilité et la décomposition du score.

6.2 Le cycle d'un incident



Comment ça fonctionne. Six états selon le NIST SP 800-61 : *Nouveau*, *Analyse*, *Confinement*, *Éradication*, *Récupération*, *Clôture*. On avance d'un état à la fois ; un retour en *Analyse* est possible depuis le confinement, l'éradication et la récupération ; la clôture exige un résumé (cause, mesures, enseignements). La machine d'état est testée à 100 %.

Chronologie immuable. Chaque ouverture, changement de statut, assignation, commentaire, action menée, IOC ou CVE associé, escalade, chasse et exclusion est écrit dans la chronologie. Des déclencheurs PostgreSQL refusent toute modification, suppression ou troncature : c'est une preuve recevable pour NIS 2 et DORA.

Niveaux SOC (ADR-022). *L1 qualifie* (acquitte, ouvre, écarte les faux positifs), *L2 investigue* (chasse depuis l'incident, enrichit, associe), *L3 traite* (réponse avancée, règles, clôture). L'escalade est motivée et sans retour en arrière.

Recommandations de réponse. Déduites des IOC, des CVE et de la phase en cours, elles proposent les gestes du NIST pour la phase : ILLWATCH recommande, l'analyste décide et déclare ce qu'il a fait (« Action menée »).

Délais cibles.

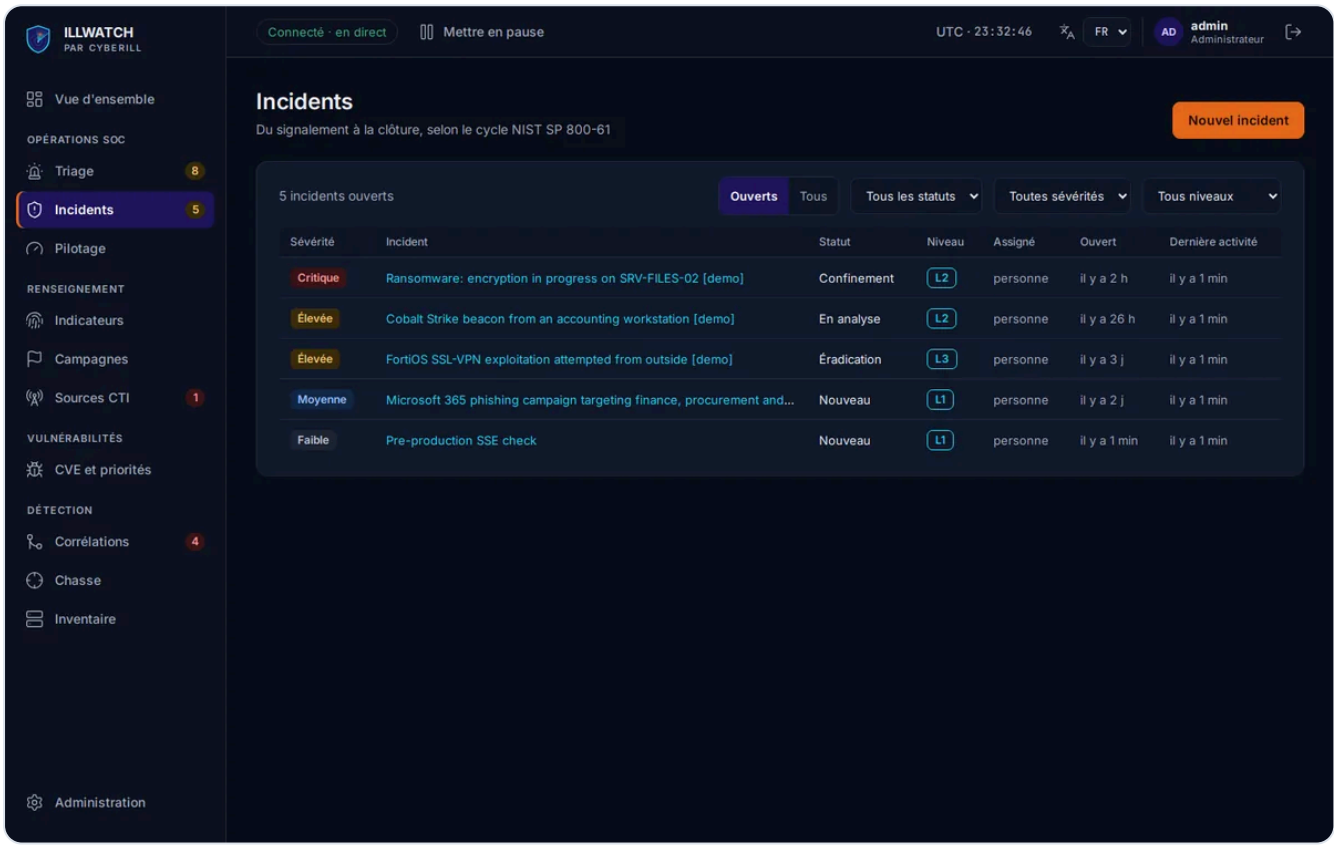
Sévérité	Prise en charge	Résolution
Critique	1 heure	24 heures
Élevée	4 heures	72 heures

Sévérité	Prise en charge	Résolution
Moyenne	24 heures	7 jours
Faible	72 heures	30 jours

La **prise en charge** est le premier geste d'un analyste (assignation, statut, escalade, note).

6.3 Utiliser

Les gestes, dans l'application et en ligne de commande, sont détaillés dans le guide, section 7.5.



7. Chasse aux menaces

À quoi elle sert. Chercher activement des traces de compromission : « une de ces adresses vues par notre proxy est-elle connue ? », « un de ces domaines ressemble-t-il à un domaine généré par un logiciel malveillant ? ».

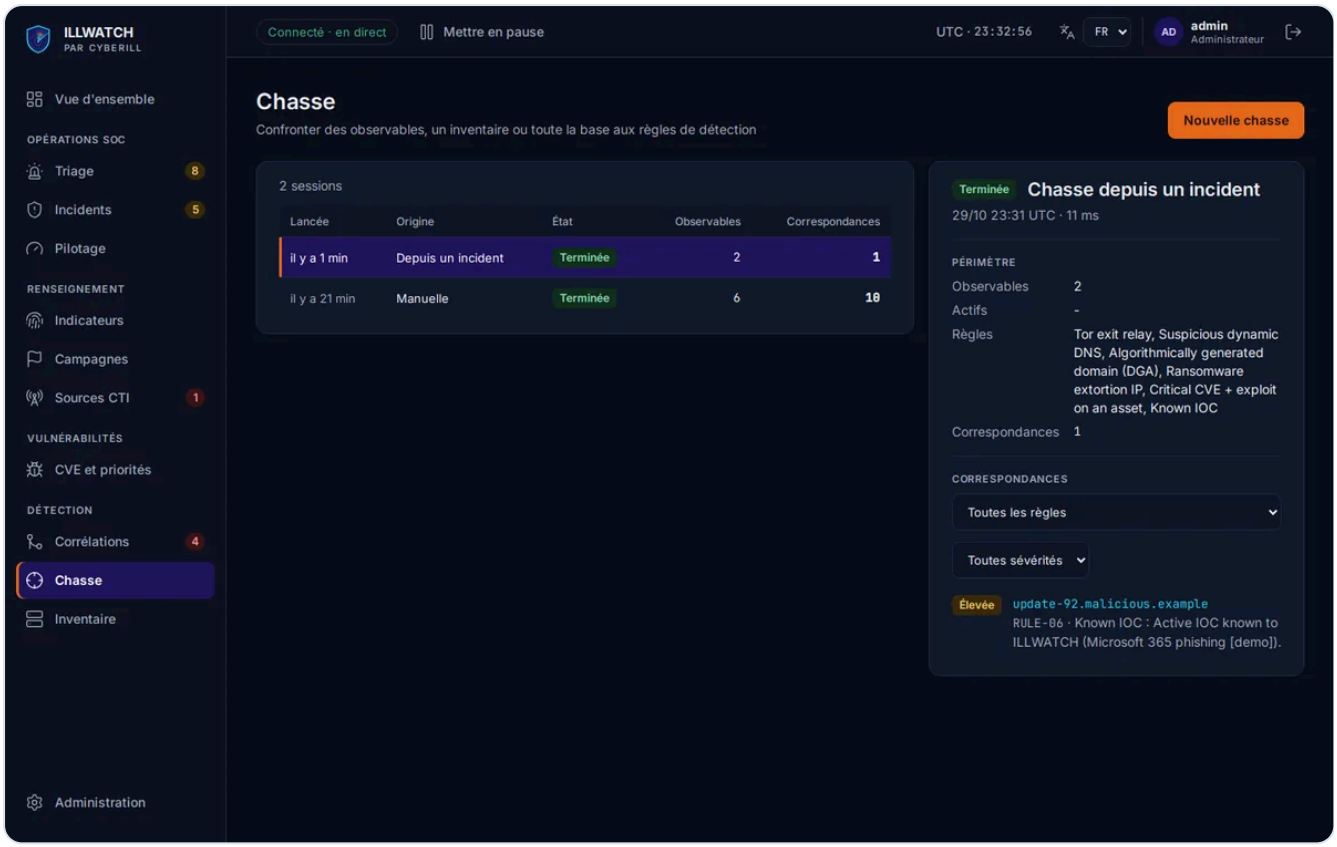
Comment elle fonctionne. Deux modes : sur des **observables soumis** (10 000 valeurs au plus, normalisées comme des IOC) ou sur **toute la base** d'IOC actifs. Chaque exécution est une **session** enregistrée ; une règle en échec rend la session *partielle* sans bloquer les autres.

Règle	Détecte	Sévérité
RULE-01	relais de sortie Tor (liste officielle)	moyenne
RULE-02	domaine chez un fournisseur de DNS dynamique gratuit	élevée
RULE-03	domaine généré par algorithme (DGA), calibré sur les 100 000 premiers domaines Tranco	moyenne
RULE-04	adresse d'infrastructure de rançongiciel connue	critique
RULE-05	CVE critique à exploit public touchant un produit de l'inventaire	critique
RULE-06	observable déjà connu comme IOC actif	celle de l'IOC

Les règles sont versionnées : chaque session garde la version des règles appliquées.

Utiliser. Écran **Chasse** (**Nouvelle chasse**) ; **Chasser depuis l'incident** sur la page d'un incident ; `illwatch hunt run --observables proxy.txt` ; chasse quotidienne automatique.

Lire le résultat. Correspondances paginées, les plus graves d'abord, filtrables par règle et sévérité, avec un lien vers l'IOC ou la CVE et le contexte ATT&CK.

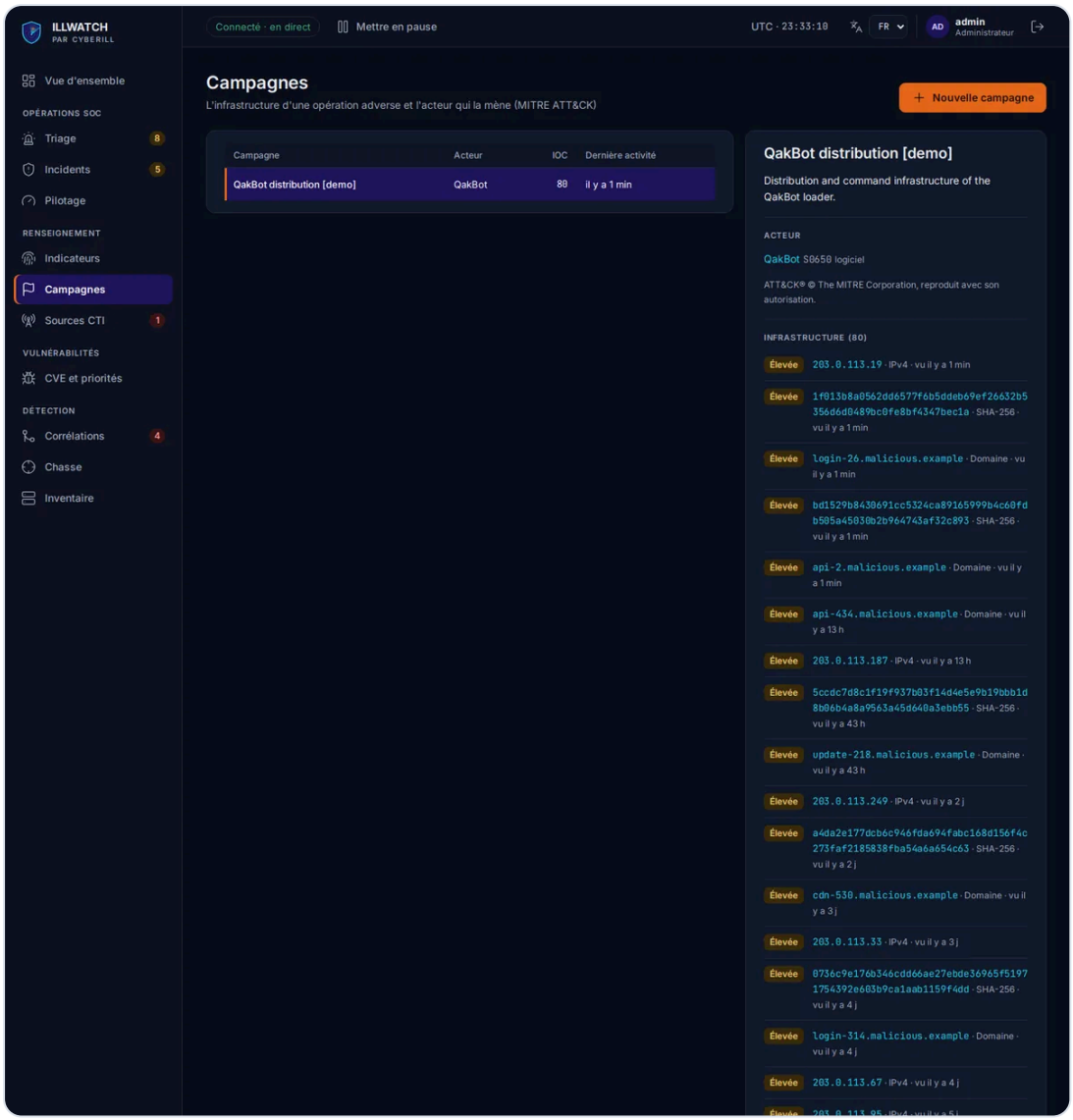

ILLWATCH
PAR CYBERILL
Connecté · en direct
Mettre en pause
UTC · 23:32:56
FR
AD
admin
Administrateur
Vue d'ensemble
OPÉRATIONS SOC
Triage 8
Incidents 5
Pilotage
RENSEIGNEMENT
Indicateurs
Campagnes
Sources CTI 1
VULNÉRABILITÉS
CVE et priorités
DÉTECTION
Corrélations 4
Chasse
Inventaire
Administration
Chasse
Confronter des observables, un inventaire ou toute la base aux règles de détection
Nouvelle chasse
2 sessions
Lancée
Origine
État
Observables
Correspondances
il y a 1 min
Depuis un incident
Terminée
2
1
il y a 21 min
Manuelle
Terminée
6
18
Terminée
Chasse depuis un incident
29/10 23:31 UTC · 11 ms
PÉRIMÈTRE
Observables 2
Actifs -
Règles Tor exit relay, Suspicious dynamic DNS, Algorithmically generated domain (DGA), Ransomware extortion IP, Critical CVE + exploit on an asset, Known IOC
Correspondances 1
CORRESPONDANCES
Toutes les règles
Toutes sévérités
Élevée
update-92.malicious.example
RULE-06 · Known IOC : Active IOC known to ILLWATCH (Microsoft 365 phishing [demo]).

8. Contexte adverse : MITRE ATT&CK et campagnes

MITRE ATT&CK est le référentiel mondial des techniques d'attaque. Une fois importé (`illwatch attack import`), chaque détection affiche sa **technique** (règles de chasse, corrélations) et, quand la source le nomme en toutes lettres, le **groupe** ou le **logiciel malveillant** cité.

Une **campagne** regroupe l'infrastructure d'une opération adverse (les IOC rattachés par valeur ou par description) et, si on le connaît, l'acteur ATT&CK qui la mène. L'**attribution par l'infrastructure** remonte ensuite partout : une correspondance de chasse, une corrélation ou un incident qui touche un IOC de la campagne affiche la campagne et son acteur.

Action	Dans l'application	En ligne de commande
Importer ATT&CK		`illwatch attack import`
Voir une technique	contexte affiché dans les détections	`illwatch attack show T1190`
Créer une campagne	**Campagnes**, **Nouvelle campagne**	`illwatch campaigns create "…" --actor S0650`
Rattacher l'infrastructure	**Rattacher de l'infrastructure**	`illwatch campaigns attach "…" --contains "Qakbot"`


ILLWATCH
PAR CYBERILL
Connecté · en direct
Mettre en pause
UTC · 23:33:10
FR
AD
admin
Administrateur
Vue d'ensemble
OPÉRATIONS SOC
Triage 8
Incidents 5
Pilotage
RENSEIGNEMENT
Indicateurs
Campagnes
Sources CTI 1
VULNÉRABILITÉS
CVE et priorités
DÉTECTION
Corrélations 4
Chasse
Inventaire
Campagnes
L'infrastructure d'une opération adverse et l'acteur qui la mène (MITRE ATT&CK)
+ Nouvelle campagne
Campagne
Acteur
IOC
Dernière activité
QakBot distribution [demo]
QakBot
80
il y a 1 min
QakBot distribution [demo]
Distribution and command infrastructure of the QakBot loader.
ACTEUR
QakBot S0650 logiciel
ATT&CK® © The MITRE Corporation, reproduit avec son autorisation.
INFRASTRUCTURE (80)
Élevée 203.0.113.19 · IPv4 · vu il y a 1 min
Élevée 1f013b8a0562dd6577f6b5ddeb69ef26632b5356d6d8489bc0fe8bf4347bec1a · SHA-256 · vu il y a 1 min
Élevée login-26.malicious.example · Domaine · vu il y a 1 min
Élevée bd1529b8430691cc5324ca89165999b4c60fdb505a45030b2b964743af32c893 · SHA-256 · vu il y a 1 min
Élevée api-2.malicious.example · Domaine · vu il y a 1 min
Élevée api-434.malicious.example · Domaine · vu il y a 13 h
Élevée 203.0.113.187 · IPv4 · vu il y a 13 h
Élevée 5ccdc7d8c1f19f937b03f14d4e5e9b19bbb1d8b06b4a8a9563a45d648a3ebb55 · SHA-256 · vu il y a 43 h
Élevée update-218.malicious.example · Domaine · vu il y a 43 h
Élevée 203.0.113.249 · IPv4 · vu il y a 2 j
Élevée a4da2e177dcb6c946fda694fabc168d156f4c273faf2185838fba54a6a654c63 · SHA-256 · vu il y a 2 j
Élevée cdn-530.malicious.example · Domaine · vu il y a 3 j
Élevée 203.0.113.33 · IPv4 · vu il y a 3 j
Élevée 0736c9e176b346cdd66ae27ebde36965f51971754392e603b9ca1aab1159f4dd · SHA-256 · vu il y a 4 j
Élevée login-314.malicious.example · Domaine · vu il y a 4 j
Élevée 203.0.113.67 · IPv4 · vu il y a 4 j

9. Partage et exports

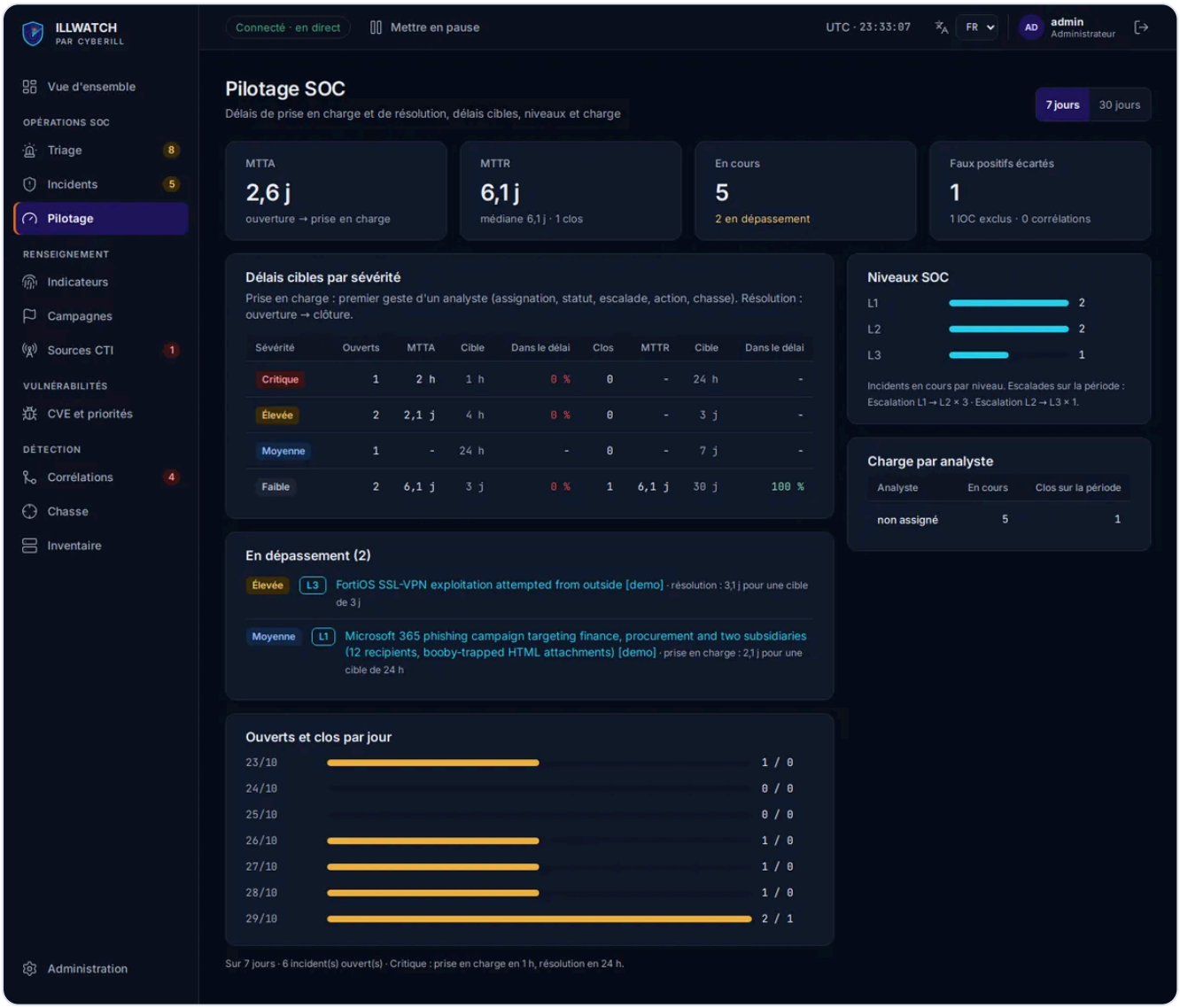
Besoin	Format	Méthode
Analyse dans un tableur	CSV (RFC 4180), cellules protégées contre l'injection de formule	**Exporter** (Indicateurs), `illwatch dashboard export`
Échange entre outils	JSON (RFC 8259)	`illwatch dashboard export … --format json`
Renseignement structuré	bundle STIX 2.1 (identifiants stables)	`illwatch stix export`, `GET /api/v1/stix/bundle`
Flux continu vers un SIEM, OpenCTI, MISP	serveur TAXII 2.1 en lecture seule : collections « indicateurs » et « campagnes »	compte **Lecteur** dédié, `https://<domaine>/taxii2/`
Inventaire	Excel ou CSV réimportable	**Exporter (Excel)**, `illwatch assets export`

Chaque export est consigné au journal d'audit (`data.export`). Les IOC exclus ne sont jamais partagés.

10. Pilotage et tableau de bord

Vue d'ensemble. Ce qui demande votre attention, puis l'état de la plateforme : file prioritaire, incident le plus grave, IOC actifs, CVE prioritaires, alertes, santé des sources, évolution de la menace sur 24 heures, 7 ou 30 jours, CVE par priorité, activité récente, IOC par type. Tout se met à jour **en direct** (flux d'évènements du serveur).

Pilotage SOC. Sur 7 ou 30 jours : MTTA (délai moyen d'ouverture à prise en charge), MTTR (délai moyen de résolution, et médiane), incidents dans le délai cible par sévérité, liste des dépassements, incidents par niveau et escalades, charge par analyste, ouverts et clos par jour, faux positifs écartés.

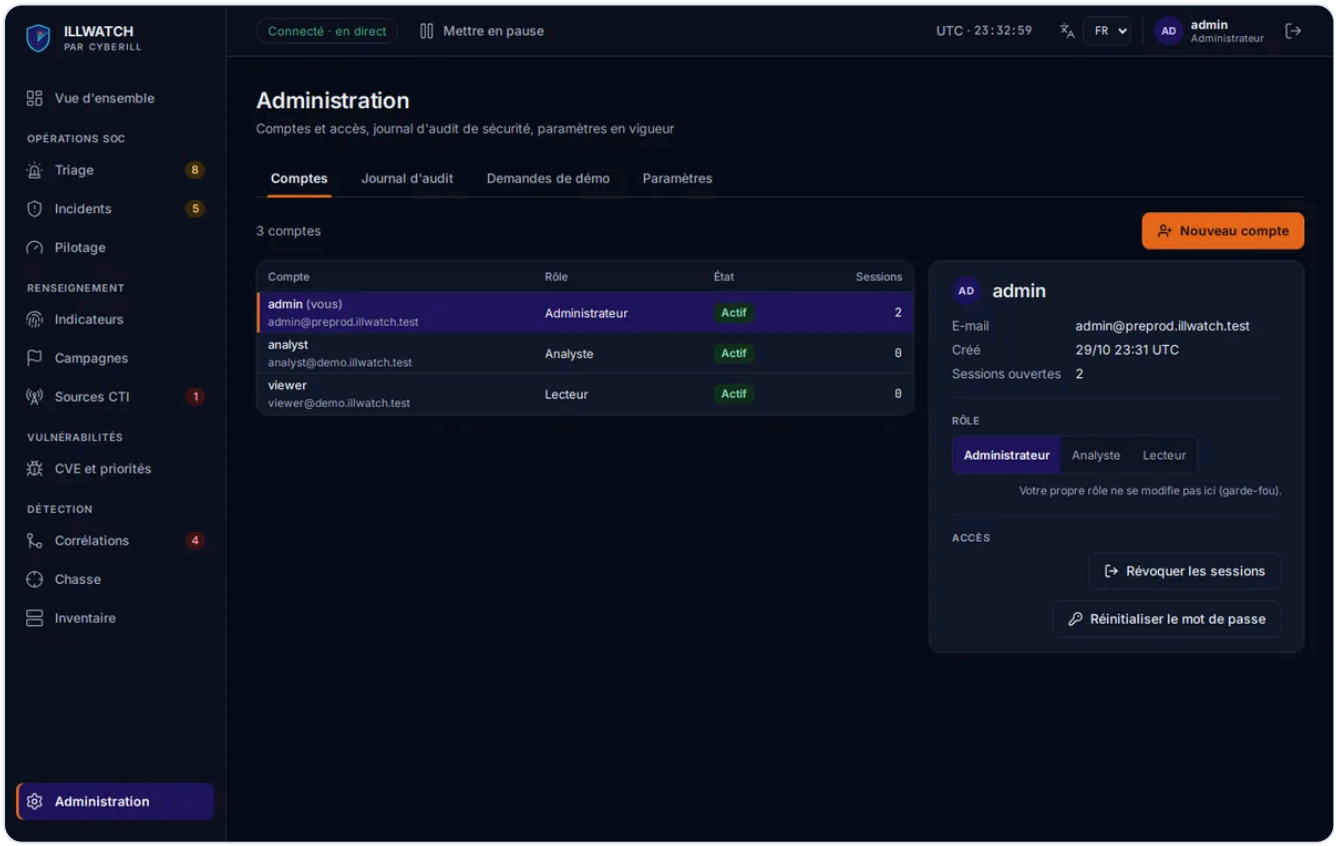


`illwatch soc metrics --days 30` et `illwatch dashboard show` donnent les mêmes chiffres en console.

11. Administration, audit et sécurité

Mesure	Ce qu'elle garantit
Mots de passe Argon2id, 12 caractères au moins	résistance au vol de la base
Jeton d'accès de 15 minutes, jeton de rafraîchissement rotatif	un jeton rejoué révoque toute la session
Limitation des connexions	5 échecs d'une adresse sur un compte, 50 sur un compte, 20 d'une adresse : refus en 429, sans bloquer le titulaire légitime
Rôle relu en base à chaque requête	une désactivation prend effet immédiatement
Rôle PostgreSQL applicatif sans droit de structure	même compromise, l'application ne peut ni modifier le schéma ni effacer l'audit
Journal d'audit en ajout seul	connexions, refus, administration, exports, chasses, inventaire, avec l'auteur, l'adresse et l'identifiant de requête
Protection SSRF, réponses plafonnées	une source hostile ne peut pas viser le réseau interne
En-têtes HTTP stricts, HTTPS par Caddy	navigateur protégé, `/docs` masqué en production

L'écran **Administration** réunit les comptes, le journal d'audit (filtres par famille d'actions et par résultat), les paramètres en vigueur (sans secret) et les demandes de démonstration.



12. Ce que la plateforme fait seule

Tâche	Fréquence	Réglage
Collecte de chaque source	selon la source (1 heure par défaut)	`DEFAULT_POLLING_INTERVAL`, écran Sources CTI
Synchronisation KEV, NVD, EPSS et recalcul des scores	toutes les 6 heures	`CVE_SYNC_INTERVAL_SECONDS`
Alerte et webhook	au franchissement du seuil	`RISK_ALERT_THRESHOLD`, `ALERT_WEBHOOK_URL`
Corrélation inventaire × CVE × IOC	chaque heure	`CORRELATION_INTERVAL_SECONDS`
Chasse sur toute la base	chaque jour	`HUNT_INTERVAL_SECONDS`
Mise à jour de DB-IP	chaque mois	`ENRICHMENT_AUTO_UPDATE`
Entretien : sessions expirées, journal des collectes au-delà de 90 jours, fraîcheur EPSS	chaque jour	
Expiration des IOC	en continu	durées par type

13. Parcours types

13.1 Le lundi matin d'un analyste

1. **Vue d'ensemble** : 8 alertes, un incident critique en confinement.
2. **Triage** : deux alertes P1 venues du catalogue KEV ; l'une touche un produit absent du parc, il l'**acquitte** ; l'autre concerne la messagerie, il **ouvre l'incident**.
3. **Corrélations** : CORR-01 sur « Messagerie » (Exchange Server, version déclarée dans la plage vulnérable) : il ouvre l'incident depuis l'évènement, qui reprend la CVE.
4. **Incidents** : il s'assigne l'incident, le passe en *Analyse*, puis l'**escalade en L2** avec le motif « serveur exposé, version vulnérable confirmée ».

13.2 Une CVE critique fait la une

1. **CVE et priorités** : recherche « fortios » ; la CVE est en P0, KEV depuis hier.
2. **Corrélations** : **Corréler maintenant** ; CORR-01 sur « Pare-feu siège ».
3. L'incident est ouvert, le correctif appliqué, l'action déclarée dans la chronologie, puis l'incident passe en *Récupération* et en *Clôture* avec son résumé.

13.3 Un nouvel équipement entre dans le parc

1. **Inventaire**, **Exporter (Excel)** ; ajout d'une ligne ; **Importer un fichier**, **Analyser** : « 1 actif à créer » ; **Importer**.
2. `illwatch cves refresh-affected` pour les plages de versions, puis **Corréler maintenant**.

13.4 Un faux positif revient sans cesse

Une adresse de résolveur DNS public déclenche une correspondance à chaque chasse : sur sa fiche, **Marquer comme faux positif** avec le motif « résolveur public de l'entreprise ». L'IOC reste en base pour l'historique, mais n'est plus ni chassé, ni corrélé, ni partagé ; seul un administrateur peut retirer l'exclusion.

13.5 Un partenaire veut recevoir nos IOC

L'administrateur crée un compte **Lecteur** dédié (`siem-partenaire`), puis transmet l'adresse `https://<domaine>/taxii2/` et les identifiants par un canal sûr. Le partenaire lit les collections « indicateurs » et « campagnes » ; il ne peut rien modifier, et son compte se désactive seul sans toucher aux autres.

14. Glossaire

Terme	Définition
ATT&CK	référentiel MITRE des techniques d'attaque (T1190 : exploitation d'une application exposée)
CVE	identifiant unique d'une vulnérabilité publiée (CVE-2021-44228 : Log4Shell)
CVSS	note de gravité technique d'une vulnérabilité, de 0 à 10
DGA	algorithme de génération de domaines utilisé par des logiciels malveillants
EPSS	probabilité qu'une CVE soit exploitée dans les 30 jours, de 0 à 1 (FIRST)
IOC	indicateur de compromission : adresse IP, domaine, URL, empreinte de fichier, e-mail
KEV	catalogue CISA des vulnérabilités déjà exploitées dans la nature
MTTA, MTTR	délai moyen de prise en charge, délai moyen de résolution
NIST SP 800-61	guide américain de gestion des incidents, référence du cycle des incidents
SSRF	attaque qui fait émettre au serveur des requêtes vers son propre réseau
STIX, TAXII	format standard du renseignement sur les menaces, et protocole pour l'échanger
L1, L2, L3	niveaux d'un SOC : qualification, investigation, traitement avancé